

SAI KUMAR VEMULA

Jersey City, NJ | 917-516-6967 | svemula127@gmail.com

linkedin.com/in/saikumar-cybersecurity | github.com/svemula17 | svemula17.github.io/sai-portfolio

PROFESSIONAL SUMMARY

Security Engineer with 5+ years across application security, cloud security, DevSecOps, detection and response, and AI security. Builds secure-by-default pipelines, infrastructure, and automation that engineering teams adopt easily, runs threat modeling and risk-based vulnerability management, and fixes problems at the source instead of only reporting them. Started in a SOC in regulated financial services, then moved into cloud security and DevSecOps. Researches and builds AI agent security: published MCP security research, built autonomous agents with scoped tool permissions and human approval gates, and secured an on-device agent that reached the finals of the Dell x NVIDIA Local AI Hackathon. Strong Python and Go automation, with deep AWS, Kubernetes, and Terraform experience. Works in the open with engineers and explains risk clearly to technical and non-technical audiences.

TECHNICAL SKILLS

AI & LLM Security: OWASP Top 10 for LLM Applications, MITRE ATLAS, MCP Security, Prompt Injection Defense, AI Agent Guardrails (Sandboxing, Tool-Permission Scoping, Credential Isolation, Human-in-the-Loop Approval), RAG Architecture Security, AI Red-Teaming, Agent Orchestration (LangGraph), AI Coding Tools & Agentic Workflows

Application & Product Security: Threat Modeling (STRIDE; PASTA Familiarity), Secure Code Review, Security Architecture Review, OWASP Top 10, API Security, Authentication & Authorization, Secure SDLC, Penetration Testing (Burp Suite, OWASP ZAP), Bug Bounty (HackerOne)

DevSecOps & Supply Chain: GitHub Actions, GitLab CI/Jenkins (Familiarity), SAST, DAST, SCA, Secret, Container & IaC Scanning, Dependency Risk Management, Policy-as-Code (OPA/Gatekeeper, Checkov), SBOM/SLSA/Artifact Signing (Familiarity)

Cloud & Infrastructure: AWS (IAM, Organizations, KMS, VPC, EKS, Lambda, GuardDuty, Security Hub, Config, Inspector, CloudTrail, Secrets Manager, WAF), Terraform, CloudFormation (Familiarity), Kubernetes, Docker, Vault; GCP and Azure (Familiarity)

Detection & Response: Splunk, IBM QRadar, ELK, SOAR, Detection Engineering, MITRE ATT&CK, Threat Hunting, Incident Response, Root-Cause Analysis, CrowdStrike Falcon EDR, Datadog Cloud SIEM (Familiarity)

Identity & Data Protection: Least-Privilege IAM, SSO/MFA, OAuth/OIDC (Working Knowledge), Secrets Rotation, KMS, TLS, DLP; Okta & Google Workspace (Limited Hands-On)

Programming: Python, Go, Bash, PowerShell, SQL, JavaScript/TypeScript (Working Knowledge), FastAPI, Flask; Java and C/C++ (Reading Only)

Compliance & Frameworks: SOC 2, ISO 27001, PCI-DSS, NIST CSF, CIS Benchmarks, HIPAA & FedRAMP (Familiarity)

PROFESSIONAL EXPERIENCE

DevSecOps Engineer

Datadog -- United States (Remote) | June 2025 - Present

- Build secure-by-default standards and paved roads across 50+ microservices: reusable Terraform modules, OPA/Gatekeeper policy-as-code, and CI/CD security gates in GitHub Actions that teams inherit without custom work.
- Own application and supply chain security tooling: SAST (Semgrep, SonarQube), SCA (Snyk, Dependabot), DAST (OWASP ZAP), container scanning (Trivy), IaC scanning (Checkov, tfsec), and secret scanning, tuned with developers to cut noise and reduce critical findings reaching production by 60%+.
- Run vulnerability management end to end: intake, validation of exploitability, risk-based prioritization, ownership assignment, SLA tracking, exception handling, verified closure, and reporting for engineering leadership.
- Lead STRIDE threat modeling, security architecture reviews, and secure code reviews for applications, APIs, and cloud services, with developer-facing fix guidance on authentication, authorization, and data handling.
- Harden AWS and Kubernetes (EKS): GuardDuty, Security Hub, Config, Inspector, and CloudTrail monitoring with Lambda auto-remediation (CIS Benchmarks, 95%+ compliance), VPC segmentation, KMS, admission policy, and image scanning.
- Drive least privilege and identity hygiene: 70% fewer wildcard IAM policies, scoped service roles, access reviews, and secrets management with Vault and AWS Secrets Manager.
- Build alerts, detections, and dashboards over CloudTrail, GuardDuty, VPC flow logs, and ELK; take part in on-call incident response, write blameless post-incident reviews, and turn findings into durable controls and runbooks.
- Implement SOC 2 and ISO 27001 requirements as engineering controls with automated evidence (audit prep down 40%); run a security champion program and developer training to drive adoption without slowing delivery.
- Alongside this role, research and publish AI security work: "MCP Security: The Attack Surface You Didn't Know You Had," covering prompt injection, tool misuse, excessive agency, data exfiltration, and tool-permission abuse in MCP and

agent integrations, plus a published analysis of the Hugging Face AI agent breach (supply chain compromise, model poisoning).

- Threat model AI agents and LLM-connected systems against the OWASP Top 10 for LLM Applications and MITRE ATLAS, identifying trust boundaries, untrusted-input paths, and over-permissioned tools, and turning findings into guardrails.
- Build AI agents with security controls designed in: scoped tool permissions, deny-by-default sandboxing, credential isolation, prompt isolation, audit logging, and human approval before high-impact actions (LangGraph agent, 7,400+ LOC, 168 tests, 16 tools).
- Built the security layer for SENTRY, an on-device AI agent that reached the finals of the Dell x NVIDIA Local AI Hackathon: deny-by-default sandbox policy, credential isolation, prompt isolation, data minimization, biometric guardrails, and auditability.
- Building an AI agent security training range (in progress) where users attack a guarded agent through prompt injection and mock tool calls, to test and teach agent security boundaries.
- Use AI coding tools in daily engineering work, reviewing and testing AI-generated output before it ships.

Cloud Security Engineer

BrowserStack -- Mumbai, India | Mar 2023 - Feb 2024

- Secured AWS across 200+ accounts in a multi-account environment: organization-level guardrails, VPC segmentation, KMS, and IAM least privilege for 150+ users/roles, with Terraform-managed baselines and drift detection.
- Automated remediation and posture management with Config rules, Security Hub, Inspector, and Lambda, reducing manual effort by 65%.
- Centralized GuardDuty and Security Hub findings into Splunk with correlation rules, dashboards, and alert tuning; investigated IAM and exposed-resource incidents and led post-incident improvements.
- Integrated scanning into CI/CD, drove remediation with engineering, and supported SOC 2, ISO 27001, and PCI-DSS evidence.

Cybersecurity Engineer

NSEIT (Deloitte SOC) -- Mumbai, India | Jan 2021 - Feb 2023

- Operated SIEM in regulated financial services: Splunk and IBM QRadar (100K+ daily events), writing and tuning correlation detections mapped to MITRE ATT&CK, with CrowdStrike Falcon EDR triage (30% false-positive reduction).
- Incident response on an on-call rotation: triage, investigation, containment, root-cause analysis, and post-incident reports; built SOAR playbooks that cut MTTR from 45 to under 15 minutes.
- Penetration testing (200+ vulnerabilities, OWASP Top 10) of web applications and APIs, including injection, authentication, and access control flaws, with remediation guidance and retesting.
- Threat hunting and investigation: IOC correlation, phishing analysis and simulations, insider-risk and data-loss cases, and DLP tuning (45% improved detection); firewall and network segmentation controls (Palo Alto, Fortinet).
- Automated analyst work with Python, Bash, and PowerShell (50% efficiency gain); supported ISO 27001 and PCI-DSS controls and vulnerability scanning (Nessus, Qualys).

SECURITY PROJECTS & RESEARCH

LangGraph Autonomous Pentest Agent

- Autonomous agent (7,400+ LOC, 168 tests, 16 tools) in Python/LangGraph that runs Nmap, SQLMap, and Metasploit, decides next steps, escalates to a human on high-impact actions, and writes severity-ranked reports.

Smart SIEM Risk Engine and VIGIL

- Smart SIEM Risk Engine: ML risk scoring in Python, FastAPI, and Scikit-learn for alert prioritization (40% noise reduction). VIGIL: real-time CCTV threat detection with YOLOv8, FastAPI, WebSocket, and React.

PUBLICATIONS & COMMUNITY

- Active HackerOne bug bounty researcher. Founder, ZHASK, an early-stage cybersecurity startup group building specialized security products.

EDUCATION

Master of Science in Cybersecurity | GPA: 3.9/4.0 | Yeshiva University, New York, NY | Expected May 2026

B.Tech in Computer Science | CMR College | 2021 | GPA: 3.9/4.0

CERTIFICATIONS & TRAINING

CompTIA Security+ (Active, May 2025) | **CompTIA CySA+** (In Progress) | **AWS Certified Security - Specialty** (In Progress) | Google Cybersecurity (Dec 2024) | ISC2 Certified in Cybersecurity Specialization (Aug 2025) | Red Hat System Administration I (May 2025) | Cyberbit Hands-On SOC Lab Program, Yeshiva University (Apr 2025)